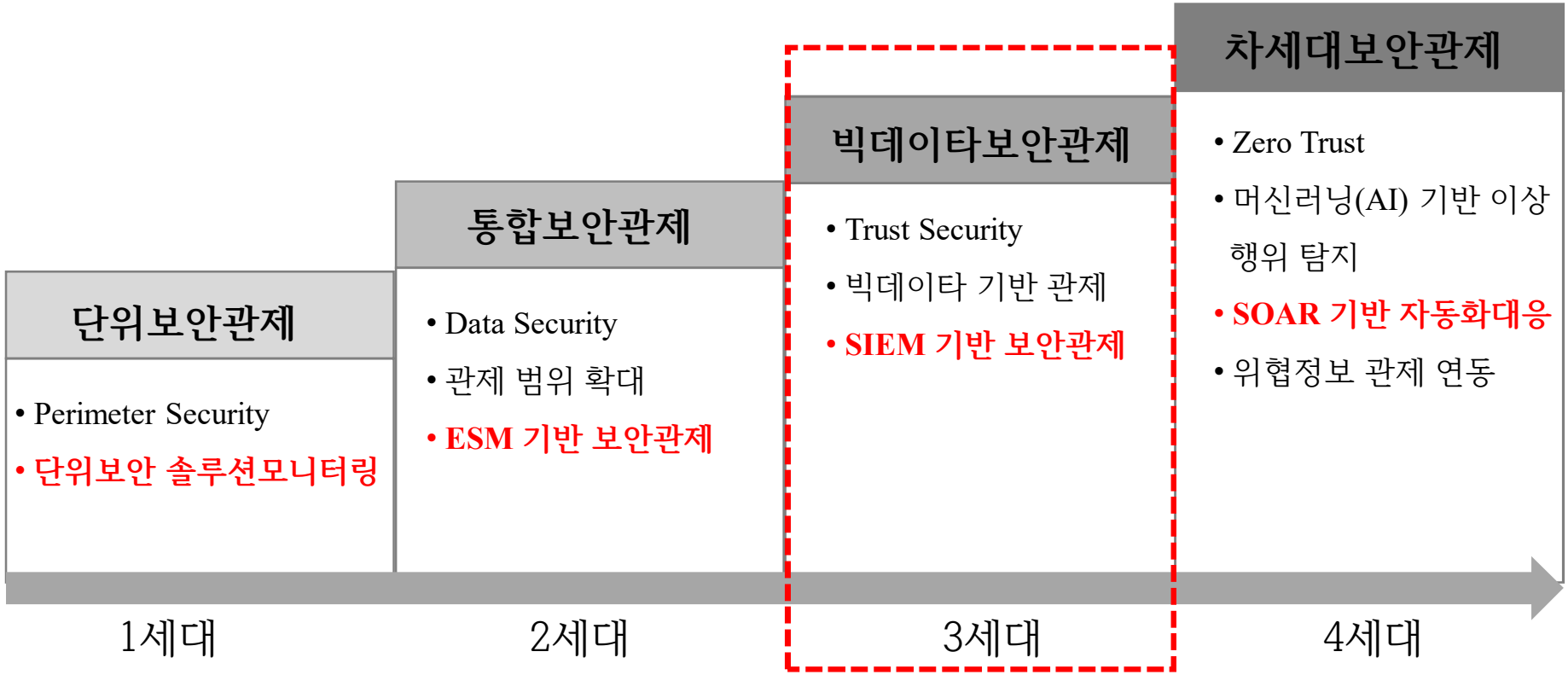
보안 관제 역사


단위보안관제
• Perimeter Security
• 단위보안 솔루션모니터링
통합보안관제
• Data Security
• 관제 범위 확대
• ESM 기반 보안관제
빅데이타보안관제
• Trust Security
• 빅데이타 기반 관제
• SIEM 기반 보안관제
차세대보안관제
• Zero Trust
• 머신러닝(AI) 기반 이상 행위 탐지
• SOAR 기반 자동화대응
• 위협정보 관제 연동
1세대
2세대
3세대
4세대

1. ESM를 이용한 관제 시스템

- 통합보안 관제 시스템

  - 기업 보안관리 시스템/통합보안 관리 시스템/ 전사적 보안관리 시스템)

  - **다양한 보안 솔루션을 하나로 모은 통합 보안 관리시스템**

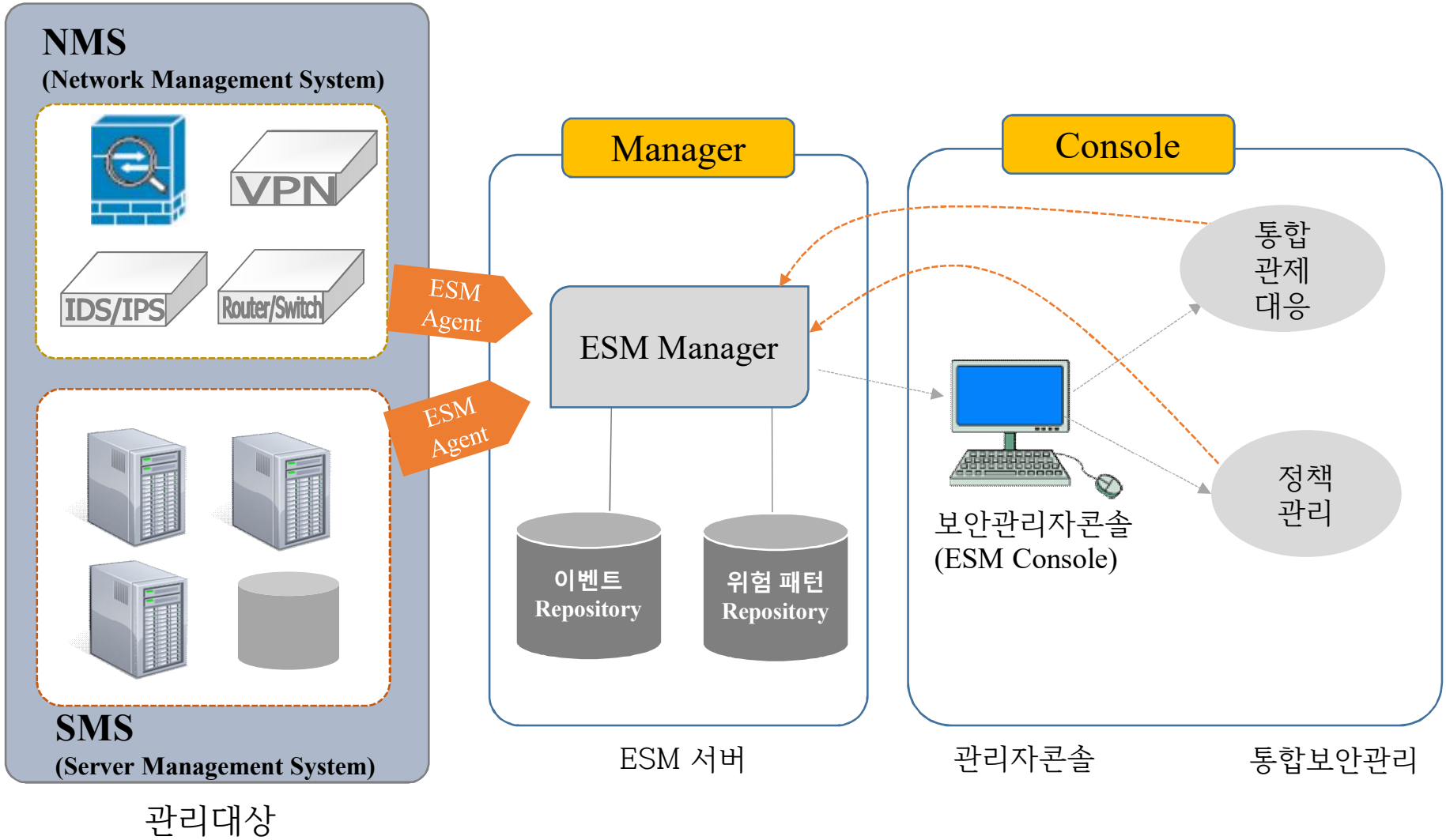
  - 다양한 보안 장비에서 발생하는 로그, 보안 이벤트를 통합적으로 수집, 관리, 분석, 통보 대응 및 보안 정책을 관리

- ESM 주요 기능 2가지

  - 서로 다른 기종의 보안 장비들을 통합 관리 기능

  - 네트워크 자원 현황을 모니터링하는 보안 모니터링 기능

ESM 구조


NMS
(Network Management System)
VPN
IDS/IPS
Router/Switch
SMS
(Server Management System)
관리대상
ESM Agent
ESM Agent
Manager
ESM Manager
이벤트 Repository
위험 패턴 Repository
ESM 서버
Console
통합 관제 대응
정책 관리
보안관리자콘솔
(ESM Console)
관리자콘솔
통합보안관리

ESM(Enterprise Security Management) 구조

Agent	• 관리 대상 보안 장비(보안장비, 시스템장비, 네트워크 장비)에 설치 • 사전에 정의된 규칙에 의한 이벤트 수집 및 보안 정책 반영 • 정책에 따른 로그 및 이벤트 데이터를 수집하여 ESM manager에 전달
Manager (Engine)	• ESM agent에 의해 수집된 데이터 분석및 저장 • 분석 결과를 ESM Console에 전달
Console	• ESM Manager에 의해 전달된 정보의 시각적 전달, 상황 판단 및 리포팅 기능 제공 • ESM Manager/Agent에 대해 규칙을 제어/통제 수행

ESM 기능

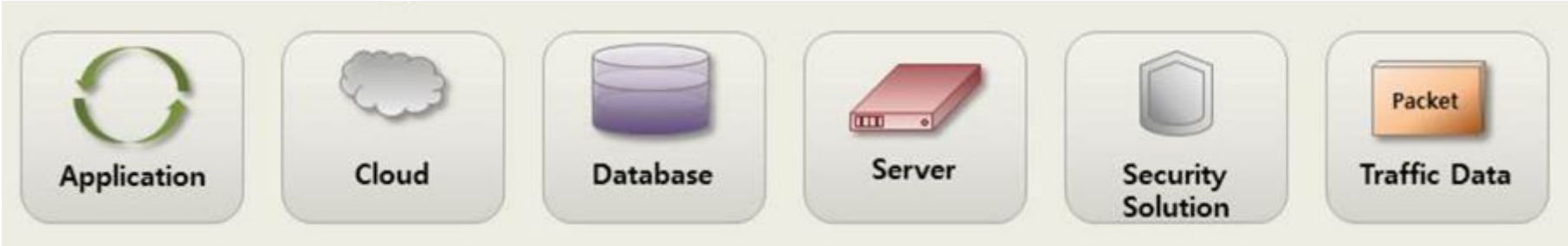
2. SIEM를 이용한 보안 관제 시스템

- SIEM(Security Information & Event Management)
- ESM의 진화된 형태 (2015년 가트너에 의해 처음으로 도입된 개념)
- **기업 정보에 대한 종합 관제 솔루션**
- 네트워크 경계부터 최종 사용자까지 로그를 중앙에 수집, 저장하고 분석 (P.158)

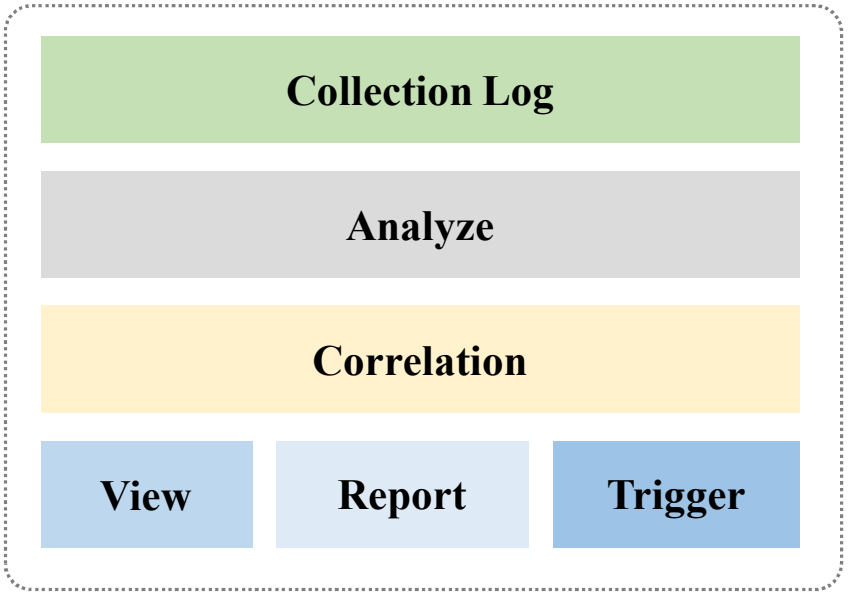
  - 통합된 보안보고와 컴플라이언스 관리를 통해 신속한 공격 탐지, 차단과 대응을 위해 실시간으로 보한 위협을 모니터링한다.
- 구축 방식은 제조사마다 다름

  - HP 아크사이트(ArcSight), IBM 큐레이더(Qrader), Splunk 등이 널리 쓰임

SIEM 구조



Infrastructure Log



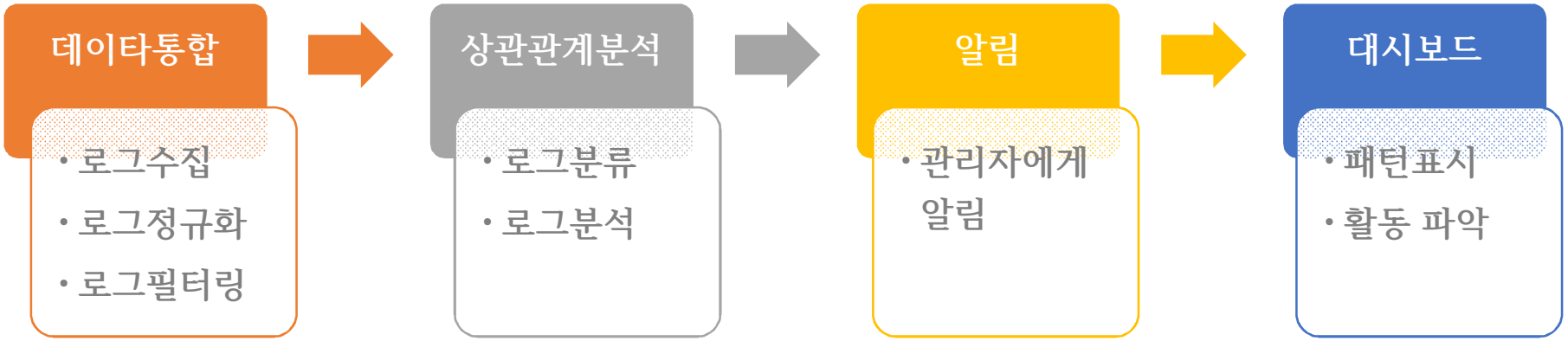
SIEM(Security Information & Event Management)

3. SIEM과 ESM 비교

	ESM	SIEM
수집·분석	• **Event 위주의 단시간(최대1일) 위협분석** • RDBMS 기반 상관분석 및 리포트, 중앙 처리 구조 • 초당 3초건 내외 수집/분석 포함	• **빅데이타 수준의 장기간(수개월) 심층분석** • Indexing, MapReduce 등 빅데이타 처리 기반 상관분석 및 리포트 • 초당 3만~5만건 이상 수집/분석 ➔ ***RDBMS 기반의 처리 속도 지연 극복***
시각화	• 대시보드, 정형보고서 제공	• 대시보드, 정형보고서, 사용자 보고서, 시각화 보고서 제공 ➔ ***다양한 Report 제공***
사용자	• 보안관리자, 관제 요원 위주	• 보안관리자, 관제요원 • 각업무시스템 별 담당자 • 개인정보보호담당자 • 대외 서비스 담당자 ➔ ***사용자 관점의 다양한 view 지원***
하드웨어	• 고가의 유닉스 서버 스템	• 저가의 리눅스 x86 시스템

	ESM	SIEM
정의	• 기업 내 다양한 보안시스템을 관제/운영/관리하여 중앙에서 통합적으로 보안 현황을 모니터링 하는 시스템	• 기업 내에서 발생하는 모든 자원의 정보 및 보안 이벤트를 통합 관리 ➔ ***장애처리 관점에서 운영 및 심층분석, 규제 준수 관점으로 확대***
수집 • 저장	• 정형데이타 기준, 원본로그 보관안함 • 수집 데이터 보존기간 :1~2개월	• 정형/비정형데이타 수용, 원본로그 보관 • 수집 데이터 보존기간 :1년 이상 ➔ ***광범위 데이터 처리 및 장기간 보관***
위협탐지	• IP, Port 등 시그니처 중심의 네트워크 계층 탐지 • 단순 패턴 기반 탐지 • 알려진 공격 위주 분석 • 단시간(최대1일) 범위 분석	• IP, Port 외 애플리케이션, 프로토콜 등 연관성 분석 및 탐지 • APT 등 알려지지 않은 공격 및 공격간의 연관성 분석, 정상상태에서의 정보위협분석 • 장시간(수개월) 범위 분석 ➔ ***심층분석, 연관분석 지원***

4. SIEM 개략적 처리 프로세스



- **로그수집(collection)**

  - 관제 대상의 Agent, SNMP, Syslog 서버로부터 로그 수집

- **로그정규화(normalization)와 필터링(filtering)**

  - 로그 형식을 표준 형식으로 변환
  - 수집한 이벤트나 플로우 데이터를 데이터베이스에 저장하려면 일정한 형태로 변환 필요
  - 업체에 따라 자동 정규화 또는 수동 정규화 방법 사용
  - 정규화 과정에서 불필요한 데이타 필터링 수행

로그 수집 전략(P.165)

- 다중 지점 로그 수집 방안

  - 내부에서 운영하는 애플케이션이 개별적으로 로그를 전송

  - 개별 수집 프로그램이나 syslog를 이용해서 로그 전송

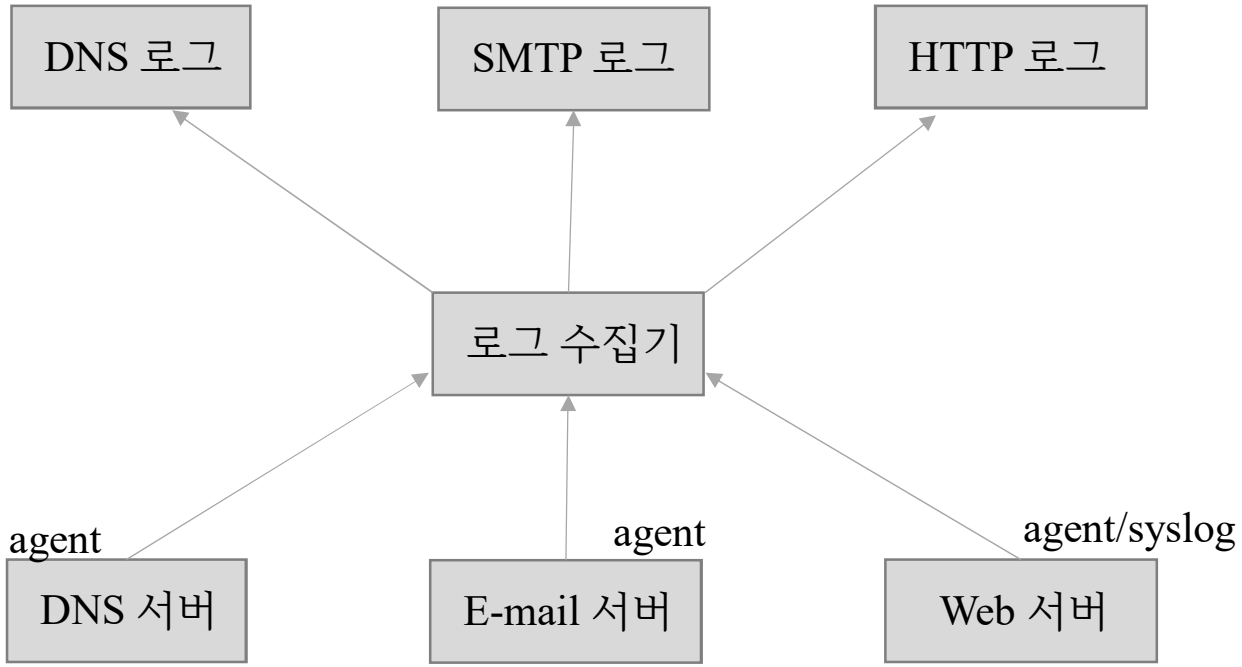
- 단일 지점 로그 수집 방안

  - 네트워크 센서에서 트래픽을 직접 입력받아 로그 생성하고 이를 색인 시스템으로 전송

  - 네트워크 센서는 프로토콜 분석까지 수행하고 서비스별 로그를 생성

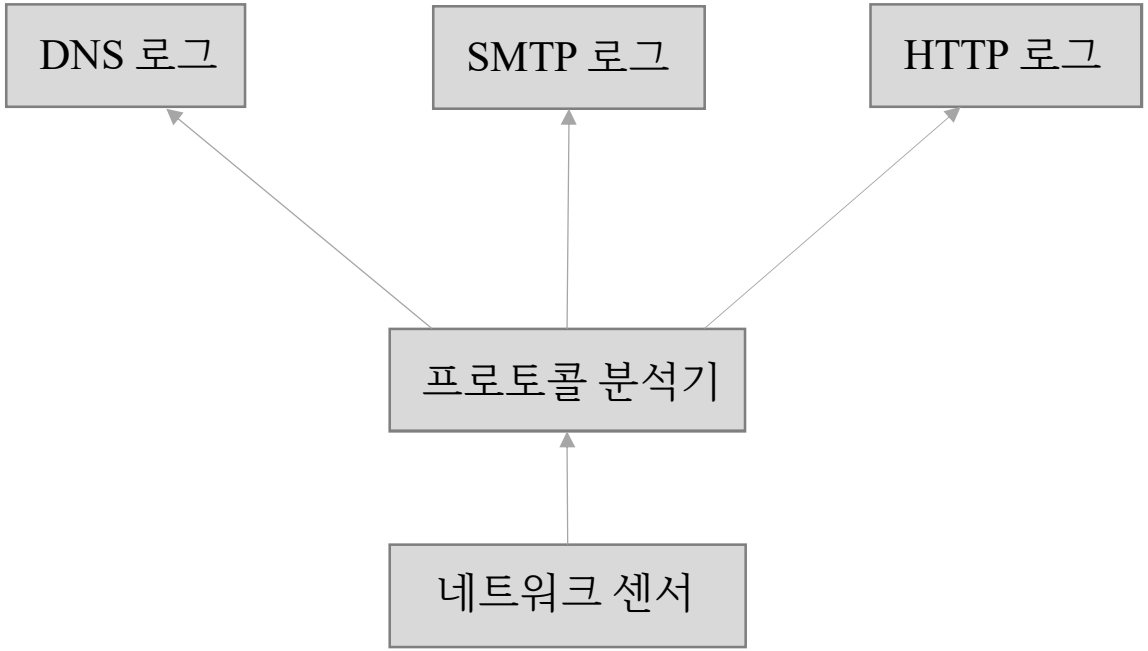
  - Zeek프로그램 하나만 갖고도 DNS, SMTP, HTTP를 모두 분석 가능

다중 지점 로그 수집 방안(P.166)



장점	단점
• 이해하기 쉬움 • 단순한 구축이 가능 • 네트워크 구조에 비의존적	• 시스템 관리가 어려움 • 관리자가 아는 항목만 수집 • 별도 서비스마다 수집해야 함 • 서비스 별 로그 형식이 다름

단일 지점 로그 수집 방안



장점	단점
• 네트워크를 지나는 모든 데이터를 로그로 생성 가능 • 다수 서비스를 단일 센서로 처리 • 생성로그 형식이 동일 • 로그를 위해서 서비스를 변경할 필요 없음	• 네트워크 가시성을 이해해야 함 • 네트워크 트래픽 처리를 위한 추가 서버 필요 • 네트워크 가시성은 복잡도를 증가

수집 로그 종류(P.180)

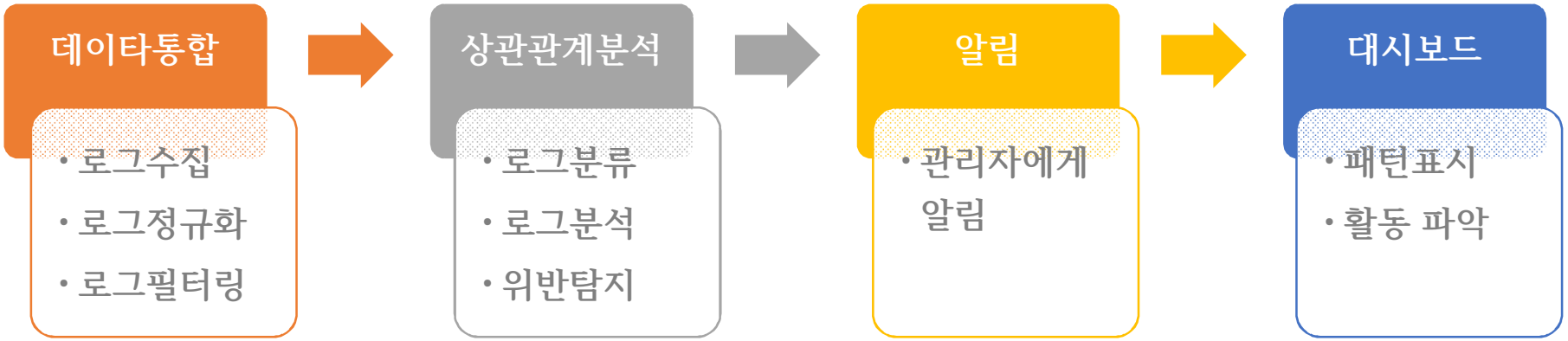
- Network log

  - 라우터, 스위치, 방화벽 등과 같이 네트워크 계층에서 수집한 로그

- Endpoint log

  - 하위 연결이 더 이상 없는 PC와 서버에서 수집한 로그

Network log	**Endpoint log**
비교적 소수의 장비 관리가 용이	많은 수의 장비 관리가 어려움
데이터 접점이 적음	데이터 접점이 많음
암호화 패킷을 분석 할 수 없음	Endpoint에서는 암호화 해재

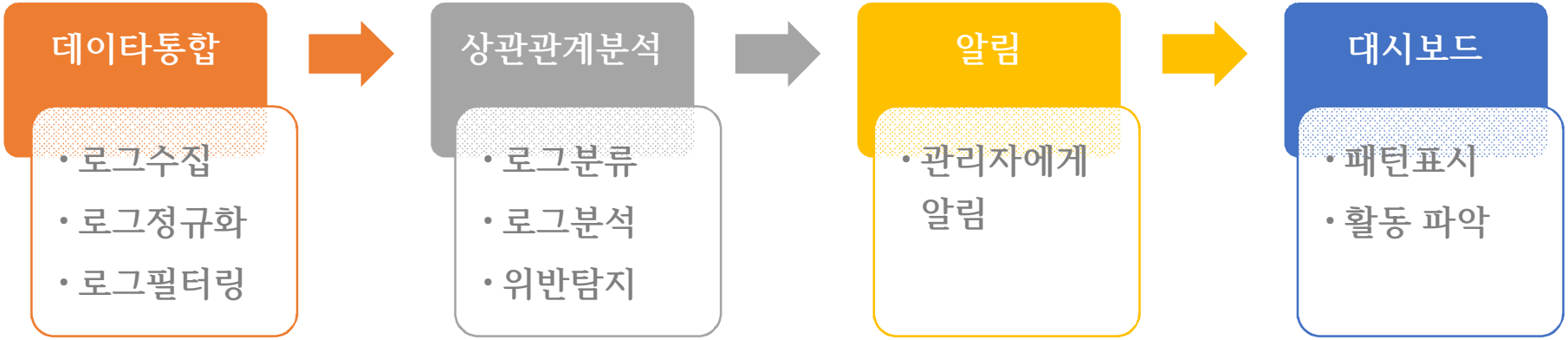


로그분류

- 수집한 이벤트나 플로우 데이터를 데이터베이스에 저장하려면 일정한 형태로 변환
- 업체에 따라 자동 정규화 또는 수동 정규격화 방법 사용
- 정규화 과정에서 불필요한 데이타 필터링 수행

상관관계분석(Correlation)

- 동기종 또는 이기종의 여러 보안 솔루션에서 발생하는 로그 패턴간에 연관성 분석
- 로그들간에 상호연관 분석을 함으로써 실시간 보안 위협을 파악하고 대응

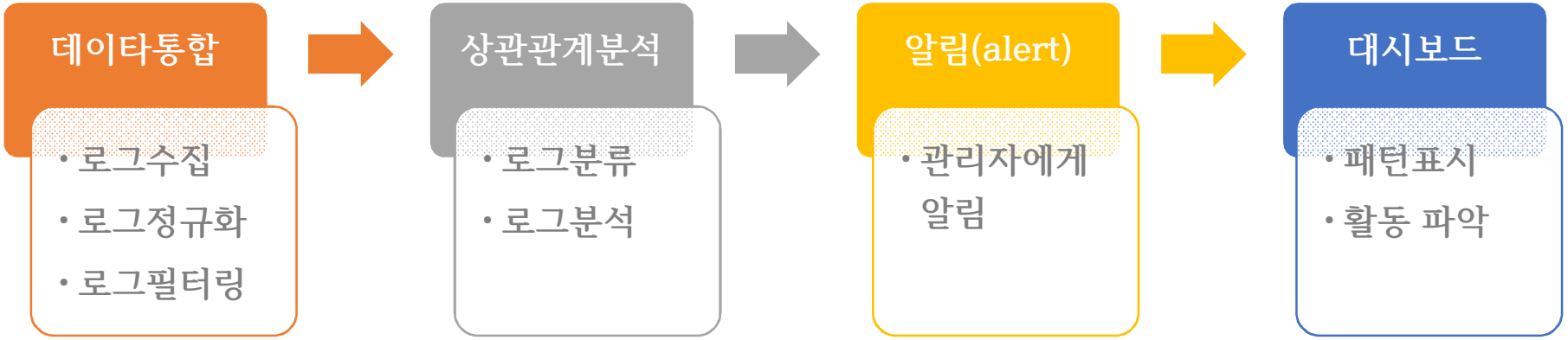


정책 위험 탐지

- 로그를 분석해서 보호 대상의 전산 환경에 발생하는 문제와 공격과 정책의 위반 탐지

- 탐지는 설정한 규칙이나 조건에 맞을 때 발생

- 탐지 규칙은 임계값을 초과하거나 통계 기반의 사용자 행위를 분석하는 방법이 있음



- 알림(Alert, 경고)

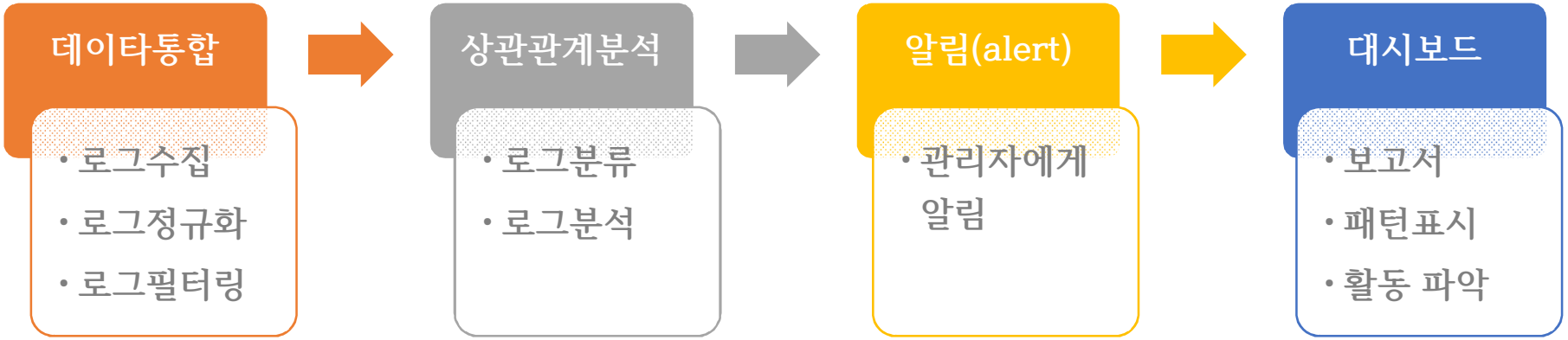
  - 경고란 보안 담당자의 검토가 필요하다는 의미

  - 정책 위반을 탐지하면 곧 경고가 생성하고 보안 담당자에게 통보

  - 경고를 발생시키는 정책은 운영하는 기업이나 기관의 관심 사안에 따라 다름

  - 경고는 중요도를 부여 할 수 있어야 함

  - 중요도는 해당 경고를 향후 상세 분석을 할 것인지를 결정하는 기준으로 사용



- 대시보드 (또는 보고서)

  - 로그는 보고서 또는 대시보드로 변환 될 수 있음

    - 얼마나 많은 접속이 발생했는가?
    - 가장 많은 접속을 일으키는 호스는 어떤 것인가?
    - 가장 많은 데이터를 인터넷으로 전송한 호스트는 무엇인가?
    - 해당 호스트를 사용하는 사용자는 누구인가?